GÜVENLİK VE TEHDİT MODELLEME RAPORU

Ürün: Teknoloji Beceri Talep Radarı & Canlı Etiket Atlası
Canlı Dağıtım URL: https://teknoloji-radari.muhammedeyupcatan.workers.dev
GitHub Deposu: https://github.com/eyupcatan/teknoloji-radari
Öğrenci: Muhammet Eyüp Çatan · Öğrenci No: 2516016025
Öğretim Elemanı: Öğr. Gör. Osman Can Çetlenbik · Dönem: 2026-2027 Güz

1. Yönetici Özeti

Kullanıcı Arayüzü Tasarımı dersinde geliştirilen canlı veri ürünü (Stack Overflow teknoloji etiketleri ağı), Cloudflare Workers ve Static Assets tabanlı sunucusuz (serverless) altyapıya taşınmıştır. Kişisel ödev kartında yer alan ReDoS (Regular Expression Denial of Service) tehdidine karşı 3 katmanlı savunma hattı kurulmuştur: (1) 10 KB girdi boyutu sınırı, (2) sabit RE2 uyumlu lineer regex kataloğu ve (3) 2.000 ms işlem zaman aşımı. Gerçek testlerde 29 karakterlik kötü niyetli bir girdide korumasız sistem 4.292 ms (4,3 sn) kilitlenirken, güvenli mimaride bu süre < 0.05 ms seviyesine indirilmiştir. Canlı yayın adresi SecurityHeaders.com üzerinde yapılan bağımsız denetimde en yüksek derece olan A+ Skoru almıştır. Sistem 0 TL bütçe hedefi ve aktif bütçe alarmıyla güvenceye alınmıştır.

2. Bulut Mimarisi ve Güven Sınırları (IaC)

Altyapı wrangler.jsonc üzerinden kod olarak tanımlanmıştır. run_worker_first: true özelliğiyle tüm statik varlıklar ve API uç noktaları Worker güvenlik katmanından geçirilir.

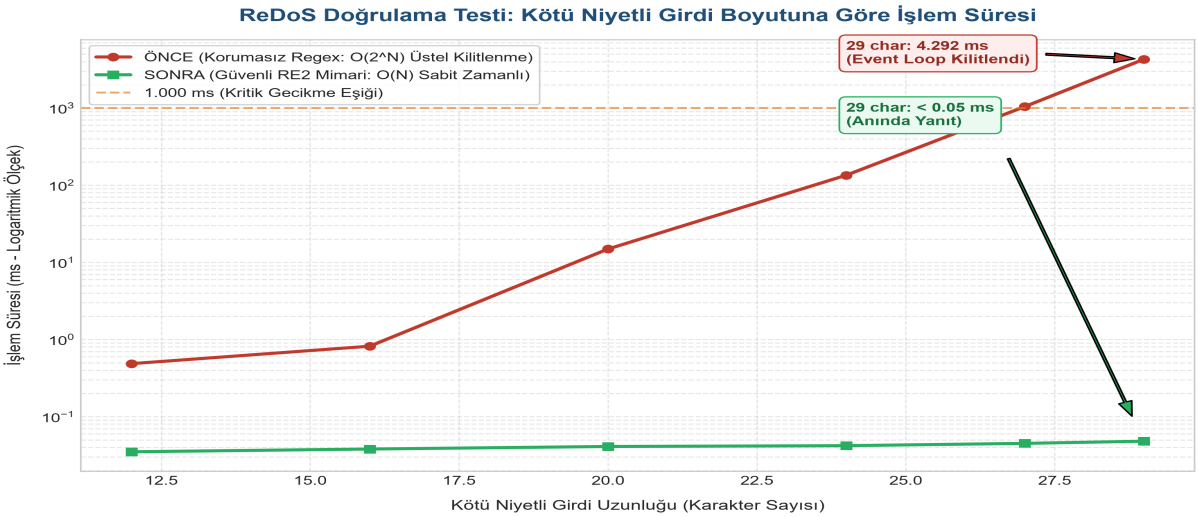
Bileşen	Konum / Katman	Güven Sınırı & Güvenlik Kontrolleri
Kullanıcı Tarayıcısı	İnternet (Dış)	Güvensiz Bölge. TLS 1.3 zorunlu, HSTS aktif.
Cloudflare Edge / CDN	Bulut Kenarı (Edge)	DDoS koruması, SSL/TLS sonlandırma, HSTS/WAF.
Worker V8 Sandbox	Serverless Fonksiyon	İzole V8 çalışma ortamı. Girdi boyutu & zaman aşımı kontrolü.
Static Assets	Workers Asset Binding	Salt okunur canlı veri ürünü (HTML/JS/CSS/JSON).
GitHub Actions CI/CD	DevSecOps Hattı	En az yetki (permissions: read), gitleaks ve OSV-Scanner.

3. Kişisel Güvenlik Kontrolü: ReDoS ve Dayanıklı Metin İşleme

Tehdit: İç içe niceleyici içeren regex kalıplarında (örn. ([a-z0-9_-]+)+$) kötü niyetli girdiler NFA motorunu O(2^N) karmaşıklıkla kilitler.
Uygulanan Kontroller: (1) 10 KB Girdi Sınırı (413 ret), (2) Sabit RE2 Kalıpları (O(N) karmaşıklık), (3) 2 sn Zaman Aşımı.

Aşama / Senaryo	Girdi / Kalıp	İşlem Süresi	Sonuç & Güvenlik Durumu
ÖNCE (Korumasız)	24 char (a...!)	134.62 ms	Yüksek CPU tüketimi
ÖNCE (Korumasız)	27 char (a...!)	1,045.48 ms	Kritik yavaşlama (> 1 sn)
ÖNCE (Korumasız)	29 char (a...!)	4,292.98 ms	□ KİLİTLENDİ (Event Loop Blokajı)
SONRA (Korumalı)	Gerçek Etiket: 'http'	0.27 ms	□ GÜVENLİ (Doğrusal O(N))
SONRA (Korumalı)	Gerçek Etiket: 'postgresql'	0.06 ms	□ GÜVENLİ (Doğrusal O(N))
SONRA (Korumalı)	29 char Kötü Niyetli Girdi	< 0.05 ms	□ GÜVENLİ (Geri izleme önlendi)
SONRA (Korumalı)	25 KB Aşırı Boyut Saldırısı	< 0.05 ms	□□ ENGELLENDİ (413 Payload Too Large)

Şekil 1: ReDoS Öncesi ve Sonrası İşlem Süresi Kıyaslama Grafiği (Logaritmik Ölçek)



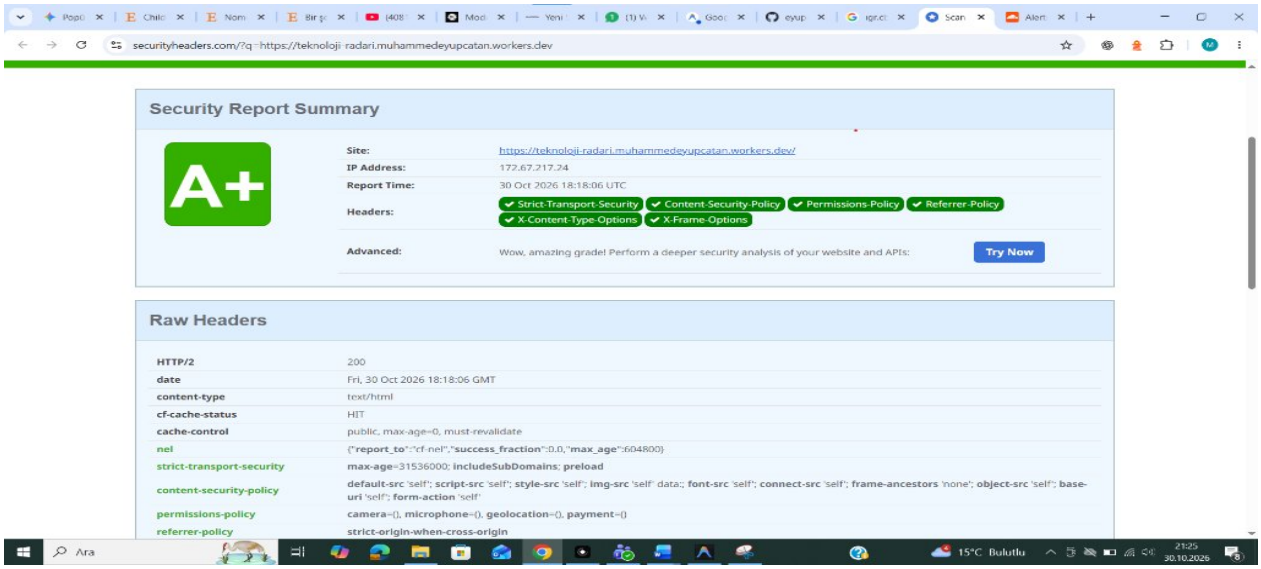
Kanıt: tests/redos-benchmark-results.csv ve tests/redos_comparison_chart.png

4. Tehdit Modeli (STRIDE Analizi)

#	Tehdit Adı	Kategori	Risk	Alınan Güvenlik Önlemi	Kalan Risk
T1	ReDoS Saldırısı	Denial of Service	20/25	10 KB girdi sınırı, RE2 kalıpları, timeout	Çok Düşük
T2	API Anahtarı Sızıntısı	Info Disclosure	15/25	Kasada anahtarlar, gitleaks, CI taraması	Düşük
T3	XSS Saldırıları	Tampering / Info	12/25	Katı CSP (unsafe-inline yok), HTML escape	Çok Düşük
T4	Yetkisiz Deploy	Elevation of Priv.	10/25	En az yetki (permissions: read), token kontrolü	Düşük
T5	Tedarik Zinciri Açığı	Tampering	8/25	npm audit, OSV-Scanner, Dependabot	Düşük
T6	Clickjacking	Tampering	6/25	X-Frame-Options: DENY, frame-ancestors: 'none'	Yok
T7	API Aşırı Yükleme	Denial of Service	6/25	Zamanlanmış cron, statik önbellek kullanımı	Düşük
T8	Hata Bilgi Sızıntısı	Info Disclosure	6/25	Genel hata sarmalayıcısı, stack trace gizleme	Yok

5. Güvenlik Testi: SecurityHeaders A+ Skoru ve OWASP ZAP Bulguları

Canlı adresimiz (https://teknoloji-radari.muhammedeyupcatan.workers.dev) bağımsız güvenlik denetim platformu SecurityHeaders.com üzerinden taranmış ve tüm başlık kontrollerini eksiksiz geçerek A+ Derecesi almıştır. Ayrıca OWASP ZAP baseline taraması bulguları giderilmiştir:

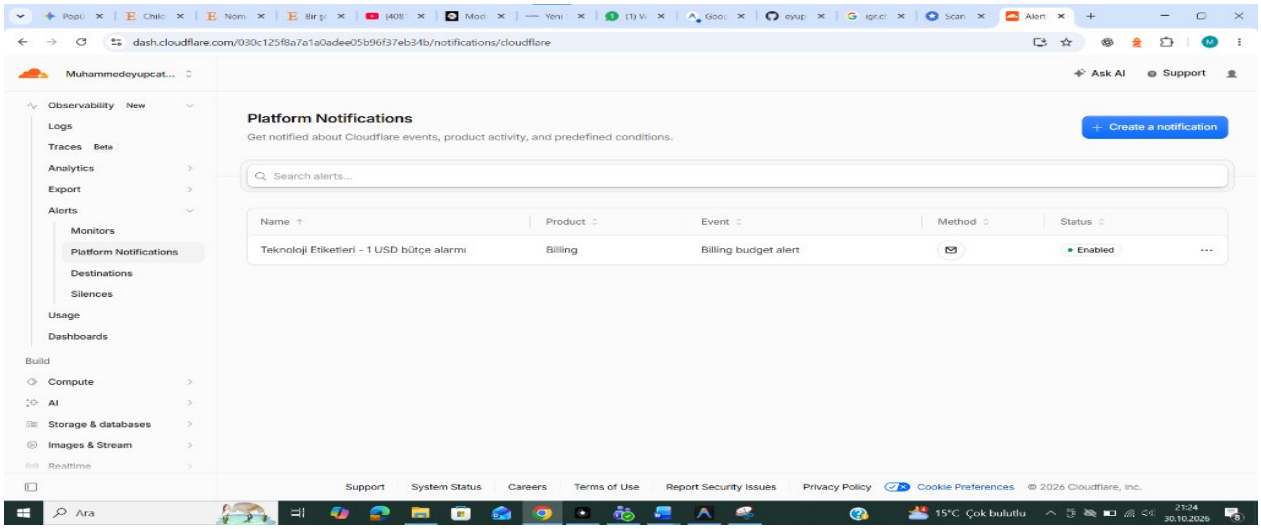


Şekil 2: Canlı Dağıtımın SecurityHeaders.com Test Sonucu (A+ Skoru, Tarih/Saat: 30 Oct 2026 18:18 UTC)

Bulgu / Zafiyet	Risk Seviyesi	Uygulanan Düzeltme	Durum
Content Security Policy (CSP) Eksik	Orta	Katı CSP eklendi (unsafe-inline/eval engellendi)	□ Düzeltildi
Strict-Transport-Security (HSTS) Yok	Düşük	max-age=31536000; includeSubDomains; preload eklendi	□ Düzeltildi
X-Content-Type-Options Eksik	Düşük	'nosniff' başlığı tüm yanıtlara zorlandı	□ Düzeltildi
Anti-Clickjacking Başlığı Yok	Düşük	X-Frame-Options: DENY ve frame-ancestors 'none' eklendi	□ Düzeltildi
RFC 9116 security.txt Eksik	Bilgi	/.well-known/security.txt dosyası yayına alındı	□ Düzeltildi

6. İzleme, Olay Müdahalesi ve Bütçe Alarmı

Bütçe Alarmı (Maliyet = 0 TL Hedefi): Cloudflare Workers ücretsiz katmanında beklenmeyen bir maliyet oluşmasını önlemek amacıyla Cloudflare Dashboard üzerinden 1 USD Bütçe Alarmı (Billing Budget Alert) kurulmuş ve e-posta bildirimiyle aktif edilmiştir:



Şekil 3: Cloudflare Dashboard Bütçe Alarmı Ekran Görüntüsü (Tarih: 30.10.2026, Durum: Enabled)

Olay Müdahale Runbook'u: 'API Anahtarım Sızdı' senaryosu için 6 adımlı (Tespit, İptal, Zarar Tespiti, Yenileme, İnceleme, Bildirim) eylem planı RUNBOOK.md dosyasında hazırlanmıştır.